

Resumo do trabalho — 14/07/2026

Projeto: Bil (dashboard de OEE para linha SMT — Jabil) **Escopo do dia:** implementação dos itens 16 (Observabilidade), 17 (Auditoria) e 18 (Segurança) da Guideline de TI da EMS IT, avaliados no documento de proposta de arquitetura técnica.

1. Metodologia

Cada item foi implementado em uma branch própria, criada a partir da `master`, testada de ponta a ponta (build, lint, testes unitários, testes e2e e verificação manual com a aplicação rodando) e depois mesclada de volta na `master`. Antes de qualquer merge, a `master` foi marcada com a tag `v1.1.0-pre-jabil-16-17-18`, preservando um ponto de rollback para o estado anterior a este trabalho.

2. Item 16 — Observabilidade

Branch: `feature/observabilidade-otel-prometheus` **Commit:** `e64f104`

- **Health Checks:** `GET /health` (via `@nestjs/terminus`), checando Postgres e Redis.
- **Métricas:** `GET /metrics` (formato Prometheus), com métricas padrão do Node.js e métricas HTTP customizadas (`http_requests_total`, `http_request_duration_seconds`) por rota/método/status.
- **Distributed Tracing:** OpenTelemetry, auto-instrumentação de HTTP/Express/Prisma/Redis, exportando para console em dev ou para um collector OTLP via `OTEL_EXPORTER_OTLP_ENDPOINT`.
- **Infra de desenvolvimento:** Prometheus + Grafana adicionados ao `docker-compose.yml`, com scrape config e dashboard (requisições/s, latência p95, taxa de erro, event loop lag) provisionados automaticamente.

Verificação: build, lint, testes unitários e e2e passando; `/health` e `/metrics` testados manualmente; traces correlacionados confirmados no console; Prometheus reportando o alvo como `up`; dashboard "Bil Backend" confirmado no Grafana via API.

3. Item 17 — Auditoria

Branch: `feature/auditoria-audit-trail` **Commit:** `f4e49f6`

- Tabela dedicada `audit_logs` (separada do log de aplicação), com ator, ação, entidade, dado **before/after** (JSON), IP e user agent.
- `User` passou a ser um `AggregateRoot`, disparando `UserRegisteredEvent` na criação da conta; o `subscriber OnUserRegistered` grava o registro de auditoria a partir do evento — o use case de registro não conhece a lógica de auditoria.
- Tentativas de login (sucesso e falha) auditadas diretamente no controller de autenticação, com IP e user agent reais da requisição.
- `GET /audit-logs` (autenticado, paginado) para consulta.

Verificação: build, lint, testes unitários e e2e passando; fluxo completo testado manualmente (criar conta → login com sucesso → login com falha → conferir os 3 registros em `/audit-logs`, incluindo IP/user agent reais).

4. Item 18 — Segurança

Branch: feature/seguranca-rbac-rate-limit-helmet **Commit:** 61f9475

- **RBAC:** User ganhou um role (OPERATOR / SUPERVISOR / ADMIN , default OPERATOR), propagado no JWT. Decorator @Roles() + RolesGuard (guard global). Rota de demonstração: GET /accounts , restrita a ADMIN .
- **Rate limiting:** @nestjs/throttler — 100 req/min globais, 5 req/min em POST /sessions (login) contra força bruta.
- **Headers de segurança:** helmet() no bootstrap; CORS configurável por ambiente via CORS_ORIGIN .

Verificação: build, lint, testes unitários e e2e passando; testado manualmente — usuário OPERATOR bloqueado (403) em rota de ADMIN , liberado após promoção de papel; POST /sessions bloqueado (429) após exceder o limite; headers Strict-Transport-Security , X-Frame-Options , X-Content-Type-Options e Access-Control-Allow-Origin confirmados na resposta.

Fora de escopo hoje (depende de decisão da Jabil): OAuth2/OIDC com IdP corporativo, cofre de segredos gerenciado (Key Vault/Secrets Manager) e criptografia de dados sensíveis em repouso — ver as 6 perguntas consolidadas na seção 10.1 do documento de proposta atualizado.

5. Merge na master e tag de rollback

Ordem de merge (da menor para a maior sobreposição de arquivos):

1. feature/observabilidade-otel-prometheus → master (sem conflitos)
2. feature/auditoria-audit-trail → master (sem conflitos)
3. feature/seguranca-rbac-rate-limit-helmet → master (conflitos em 7 arquivos — .env.example , package.json , pnpm-lock.yaml , env.ts , main.ts , http.module.ts e user.ts — todos resolvidos combinando as duas adequações, sem perda de funcionalidade de nenhum dos lados)

Após o merge, o Prisma Client foi regenerado, as 3 migrations (init , add_audit_log , add_user_role) foram validadas rodando prisma migrate deploy do zero em um banco limpo, e a aplicação mesclada foi testada de ponta a ponta com todas as três features funcionando juntas na mesma execução (health check, RBAC, audit trail e métricas).

Tag de rollback: v1.1.0-pre-jabil-16-17-18 , apontando para o estado da master imediatamente antes deste merge.

6. Estado final

- master local e remota atualizadas com os 3 itens implementados, testados e mesclados.
- Documento docs/jabil-proposta-arquitetura-2026.md (e PDF correspondente) atualizado: itens 16 e 17 marcados como **Atende** (implementados), item 18 como **Atende (parcial)** com as pendências que dependem da Jabil explicitadas na nova seção 10.1.
- Resultado consolidado da guideline: de 18 itens, **9 atendem hoje sem nenhuma adequação pendente, 8 atendem com adequação já descrita e majoritariamente implementada, e 1 é não aplicável à stack** com equivalente proposto (documentação XML).